PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

IA et Cybersécurité

03-95 Conseil de l'IA et du numérique - IA et cybersécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'IA peut automatiser la détection d'anomalies et le DevSecOps, mais elle génère aussi des vulnérabilités que l'expertise humaine doit superviser.
2. L'usage de l'IA par les attaquants crée une menace symétrique en augmentant la rapidité et l'efficacité des offensives.
3. La recherche de performance via l'IA peut engendrer un dilemme de souveraineté en accroissant la dépendance technologique et la surface de risque cyber.

Dynamique de l'équilibre attaque/défense

Notion	À retenir
Réaction technologique	Chaque avancée provoque une réaction systématique. Ex: **chiffrement** (années **1990**) → contournement ; **virus** (début **2000**) → innovation défense.
Compétences et motivations	L'IA aide la détection d'anomalies, mais l'**expertise humaine** reste indispensable face aux vulnérabilités générées. Risque de **déclassement** sans intégration des nouveaux usages.

Triple dimension de l'impact de l'IA

Notion	À retenir
Vulnérabilités propres	Attaques originales comme le **prompt injection** ou l'**empoisonnement par les données d'apprentissage**. L'IA génère des vulnérabilités difficiles à détecter à temps.
IA de défense	Automatisation des tâches et détection d'anomalies via des **quantités phénoménales de données techniques**. Aide au **DevSecOps** (développement, sécurité, exploitation).
IA offensive	Automatisation des attaques pour **efficacité** et **rapidité**. Le modèle **Mythos** (Anthropic) exploite les failles des logiciels, navigateurs et systèmes d'exploitation.

Défis opérationnels et vulnérabilités

Notion	À retenir
Expertise et DevSecOps	L'**expertise humaine** est cruciale car l'IA génère des vulnérabilités non détectées. L'**IA agentique** en **DevSecOps** nécessite un encadrement pour limiter les risques.
Risque de saturation	Le rythme croissant du **patching** sature les acteurs. Risque critique en **informatique industrielle** où les mises à jour ne sont pas **systématisées**.
Exploitation des correctifs	Un **correctif** révèle la vulnérabilité. Les **attaquants dopés à l'IA** exploitent ces patchs pour cibler ceux n'ayant pas encore fait la **mise à niveau**.

Enjeux stratégiques, marketing et souveraineté

Notion	À retenir
Stratégies marketing	Utilisation d'effets d'annonce et de la **dangerosité** des modèles pour afficher les performances et attirer les investisseurs (ex: **OpenAI**, **GPT 2.0**, **février 2019**).
Dépendance et lock-in	Risque de **lock-in** par solutions propriétaires, coûts de dépendance, extension de la **surface du risque cyber** et phénomène du **shadow AI**.
Dilemme de souveraineté	Arbitrage **performance** vs **autonomie**. La France subit une **asymétrie d'informations** face aux écosystèmes **américain, britannique et chinois**.

Impératif de l'évaluation et de la maîtrise européenne

Notion	À retenir
Audit indépendant	L'**AI Security Institute** britannique (créé en **2023**) a publié le **13 avril 2026** un audit de **Mythos** : il exploite surtout des systèmes à **posture de sécurité faible**, d'où l'importance des fondamentaux.
Asymétrie d'information	La **France** est en déséquilibre face aux écosystèmes **britannique, américain et chinois**, menaçant la qualité des **talents** et de l'écosystème.
Écosystème européen	Structuration accélérée d'un écosystème **public-privé** autour de l'**INESIA** et des **laboratoires IA de pointe** en Europe.

Synthèse des recommandations de gouvernance

Notion	À retenir
Intégration sécurité	Penser les cadres de gouvernance et de sécurité dès l'adoption. Créer une fonction permanente de découverte, qualification et remédiation autonomes de vulnérabilités (prolongement de la méthode **DevOps**).
Référentiels existants	Se mettre à niveau en conformité. Appliquer les principes fondamentaux : mises à jour régulières et contrôles d'accès rigoureux. Utiliser des référentiels généraux comme la directive **NIS2**.
Coopération public-privé	Ne pas céder à la panique. L'IA est **agnostique** (aide attaquants et défenseurs). L'évaluation des modèles en Europe doit reposer sur la coopération autour de l'**INESIA** et de laboratoires de pointe.

Pièges et confusions

- ⚠ Confondre la cybersécurité de l'IA (protection des systèmes d'IA) avec la cybersécurité par l'IA (usage de l'IA comme outil de défense).
- ⚠ Croire que l'IA peut totalement remplacer l'expertise humaine.
- ⚠ Penser que l'augmentation du rythme de patching est uniquement positive sans risque de saturation des services informatiques.
- ⚠ Ignorer que l'IA est une technologie agnostique qui aide aussi bien les attaquants que les défenseurs.

Sigles et définitions

L'IA	intelligence artificielle
L'ANSSI	Agence nationale de la sécurité des systèmes d'information
Le shadow AI	usage non encadré de l'intelligence artificielle pouvant entraîner des fuites de données
L'INESIA	Institut national pour l'évaluation et la sécurité de l'IA
Le NIS2	directive européenne 2022/2555 imposant des obligations de cybersécurité aux entités essentielles et importantes
Le DevSecOps	approche réunissant le développement, la sécurité et l'exploitation logicielle

Auto-test

1. Qu'est-ce que le patching ?
2. Quel est le risque lié au shadow AI ?
3. Quel institut a publié le 13 avril 2026 un audit indépendant de Mythos ?
4. Quelle directive impose des obligations de cybersécurité aux entités essentielles et importantes ?
5. Que recouvre la « cybersécurité face à l'IA » ?

Réponses : **1.** le mécanisme de correction des vulnérabilités logicielles · **2.** des fuites de données · **3.** L'AI Security Institute britannique (créé en 2023). · **4.** NIS2 · **5.** L'automatisation offensive : l'IA rend les attaques plus rapides et efficaces.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.